

Cyber Tabletop Exercise

DDoS Against Online and Mobile Banking

Facilitation-Ready Exercise Package

This document provides a complete tabletop exercise for a financial-services organization experiencing a high-volume denial-of-service event against online and mobile banking channels during peak customer usage.

EXERCISE TYPE

Facilitated tabletop exercise

AUDIENCE

Executive, operational, and technical stakeholders

SUGGESTED DURATION

90 minutes

SCENARIO SOURCE

Derived from uploaded scenario and evaluation feedback

THREAT THEME

Public-facing availability disruption / DDoS

CLASSIFICATION

Internal use for exercise facilitation

Exercise material only. Do not initiate live response actions, contact providers, or communicate externally based solely on exercise content.

Document Control

Field	Details
Exercise title	DDoS Against Online and Mobile Banking
Exercise format	Facilitated discussion-based tabletop exercise with phased injects, decision points, expected actions, and debrief.
Primary participants	Crisis management, cyber incident response, digital banking operations, IT infrastructure, customer support, legal/compliance, communications, vendor management, and executive stakeholders.
Source basis	Uploaded DDoS scenario content and uploaded evaluation feedback. This version strengthens structural completeness while preserving the original attack progression and technical accuracy.
Distribution	Internal use for exercise design, facilitation, observation, and after-action planning.

Evaluation feedback integrated. The source scenario was already realistic, coherent, and highly relevant. This revised exercise adds the design elements identified as missing or insufficiently explicit: objectives, scope, roles, facilitation timeline, discussion questions, expected actions, coordination mechanisms, decision ownership, and measurable success criteria.

Table of Contents

1. Exercise Overview	Scenario purpose and core theme
2. Objectives and Success Criteria	Measurable exercise outcomes
3. Scope, Assumptions, and Constraints	Boundaries for play
4. Participant Roles and Decision Rights	Role expectations and RACI
5. Rules of Engagement	Exercise conduct
6. Facilitation Plan and Timeline	Exercise flow and inject cadence
7. Initial Situation Brief	Opening scenario narrative
8. Phased Injects	Detection, mitigation, stabilization, recovery

9. Coordination Mechanisms and Communications	Operating rhythm and templates
10. Business and Technical Impacts	Impact areas to explore
11. Debrief, Observation, and Improvement Planning	Lessons learned and action capture
12. MITRE ATT&CK Mapping	Final framework mapping

1. Exercise Overview

Scenario Summary

A banking organization providing consumer online and mobile banking services experiences a high-volume denial-of-service event against public digital banking channels during a peak usage window. Customers begin reporting login failures, mobile app timeouts, and intermittent service availability. The public status page is also unstable, reducing the bank's ability to communicate service status externally.

The bank must coordinate technical response, executive decision-making, business continuity, customer support, public communications, vendor escalation, and recovery. The exercise emphasizes availability, customer trust, service prioritization, and governance under uncertainty.

Core Theme

This exercise tests whether the organization can coordinate cyber, technology, business, legal/compliance, customer support, and communications functions during a public-facing digital banking outage that directly affects customer confidence and operational resilience.

Exercise Design Principles

- **Realistic but controlled:** The scenario is plausible for a financial institution but does not assume customer data theft, malware, fraud, or core banking compromise unless introduced by the facilitator.
- **Decision-focused:** Participants should explain who owns each decision, what information they need, what they would communicate, and how they would document actions.
- **Cross-functional:** The incident cannot be managed by the SOC alone; success requires coordinated technical, business, customer, regulatory, and executive actions.
- **Improvement-oriented:** The goal is to identify capability gaps, not to test individual performance.

Primary Exercise Questions

- How quickly can the organization recognize a public-facing availability event as a major cyber incident?
- Who activates the incident bridge, crisis-management structure, DDoS provider engagement, failover, and customer communications?
- How are critical customer journeys prioritized when not all digital services can be maintained at the same level?
- How does leadership communicate transparently without over-confirming technical details or restoration timing?
- What evidence, metrics, and decisions must be preserved for after-action review, vendor accountability, and regulatory assessment?

2. Objectives and Success Criteria

By the end of the exercise, participants should be able to demonstrate the following capabilities.

Objective	Expected Demonstration	Measurable Success Criteria
1. Detect, triage, and escalate a major digital banking disruption.	Participants validate customer impact, technical symptoms, and severity using monitoring, customer support, and business inputs.	Severity classification, incident bridge, incident commander, and stakeholder notifications are agreed during Inject 1.
2. Coordinate response across cyber, IT, business, and crisis-management functions.	Participants describe an operating model with clear technical bridge, crisis cell, executive update, and scribe functions.	Decision owners and update cadence are documented; technical and business teams share a common operating picture.
3. Prioritize critical customer services under constrained availability.	Participants rank online/mobile banking journeys and identify which functions may be degraded, rate-limited, or paused.	Critical services, nonessential services, and customer workaround options are defined before restoration decisions are made.
4. Activate DDoS mitigation and resilience capabilities appropriately.	Participants explain triggers for engaging providers, scrubbing, rate limiting, CDN/WAF rules, DNS changes, and failover.	Provider engagement criteria, approval path, operational risks, and rollback considerations are captured.
5. Manage customer, employee, executive, and regulatory communications.	Participants produce audience-specific messaging that is timely, accurate, approved, and does not speculate on attribution.	Holding statement, internal guidance, contact center script, and regulator-assessment owner are identified.
6. Restore services and transition from crisis to controlled recovery.	Participants define restoration criteria, monitoring period, evidence preservation, and after-action requirements.	Stand-down criteria, recovery communications, evidence plan, and improvement actions are agreed during Inject 4.

Facilitator scoring prompt: For each objective, ask observers to rate confidence from 1 to 5: 1 = not confident, 2 = slightly confident, 3 = somewhat confident, 4 = fairly confident, 5 = completely confident. Capture concrete evidence for each score.

3. Scope, Assumptions, and Constraints

In Scope

- Online banking portal availability.
- Mobile banking access and authentication.
- Customer login failures and account-access issues.
- Public status page reliability and alternate notification channels.
- DDoS mitigation activation, traffic filtering, CDN/WAF coordination, DNS changes, and controlled failover.
- Incident escalation, crisis-management coordination, and decision logging.
- Customer support surge management and branch/contact center guidance.
- External communications, regulatory assessment, executive reporting, recovery, and lessons learned.

Out of Scope

- Full packet-level forensic analysis.
- Malware reverse engineering.
- Fraud investigation beyond availability-related customer impact.
- Confirmed customer data compromise; no data theft is initially known.
- Core banking compromise; the exercise focuses on digital-channel availability.
- Third-party provider internal remediation beyond simulated status updates.
- Real production changes, live vendor calls, or external communications.

Baseline Assumptions

- The organization has documented incident-management and crisis-management processes.
- The organization has contracted DDoS mitigation, CDN/WAF, ISP, or equivalent provider options available.
- Digital banking services include authentication, account viewing, customer-initiated transactions, and a public status page.
- Alternate customer-service channels exist, such as contact center, branches, secure messaging, or IVR announcements.
- Participants respond based on their current roles, responsibilities, authorities, and documented processes.
- There is no initial evidence of credential theft, unauthorized transactions, ransomware, destructive activity, or customer data exfiltration.

Exercise Constraints

Constraint	Implication for Participants
Information will be incomplete.	Participants must make time-bound decisions while documenting assumptions and uncertainties.
Restoration estimates may be unreliable.	Communications should avoid overpromising and should distinguish confirmed facts from working hypotheses.
Mitigation may degrade some services.	Teams must decide which services are critical and which can be temporarily restricted.
Status page instability reduces transparency.	Participants should consider alternate communication channels and status-page resilience.

4. Participant Roles and Decision Rights

Recommended Participants

Executive / Strategic

- Crisis lead or executive sponsor
- Digital banking business owner
- Operations executive
- Communications/media lead
- Legal, compliance, privacy

Operational

- Incident commander
- SOC lead
- IT operations/infrastructure lead
- Customer support/contact center lead
- Vendor management lead

Technical

- Network/DDoS mitigation lead
- Online/mobile banking application owner
- Identity/authentication lead
- Monitoring/logging lead
- Resilience/failover lead

Exercise Support Roles

- **Facilitator:** Delivers injects, controls pace, asks clarifying prompts, and keeps discussion aligned with objectives.
- **Scribe:** Captures decisions, owners, action items, risks, unanswered questions, and observation scores.
- **Observers:** Assess behaviors against objectives and note gaps without participating in decision-making unless invited.

Decision Rights and Coordination RACI

Decision / Activity	Accountable	Responsible	Consulted	Informed
Declare major incident and activate incident bridge	Incident commander or duty incident manager	SOC lead, IT operations lead	Digital banking owner, customer support, communications	Executive sponsor, legal/compliance
Activate crisis-management structure	Crisis lead / executive management	Incident commander, business operations lead	Legal/compliance, communications, digital banking	Board/executive stakeholders as appropriate
Engage DDoS mitigation provider, ISP, CDN/WAF provider	Technology/cyber leadership according to policy	Network/DDoS lead, vendor management	SOC, application owner, legal/procurement if needed	Crisis lead, communications, customer support
Approve controlled failover or service degradation	Crisis lead with technology/business owner input	IT operations, resilience lead, application owner	SOC, customer support, legal/compliance	Executives, contact center, branches
Approve customer-facing messages	Communications lead and crisis lead	Customer support, digital banking, legal/compliance	Incident commander, SOC for technical accuracy	Employees, executives, regulators as appropriate

Decision / Activity	Accountable	Responsible	Consulted	Informed
Assess regulatory or supervisory notification obligations	Legal/compliance lead	Privacy, risk, business owner, incident commander	Communications, executive sponsor	Crisis cell, board/ executive stakeholders
Stand down crisis mode and enter recovery	Crisis lead	Incident commander, IT operations, business owner	SOC, communications, legal/compliance, customer support	All affected stakeholders

Facilitation watchpoint: Do not allow a vague “the team will decide” answer. Ask participants to name the decision owner, approval path, inputs required, timing, and fallback if the owner is unavailable.

5. Rules of Engagement

- This is a no-fault, discussion-based exercise. The objective is to identify improvement opportunities, not to evaluate individual performance.
- Real-world incidents take priority. Participants may step away for operational needs.
- Participants should respond as they would in their real roles using current procedures, authorities, tools, and escalation paths.
- Do not “fight the scenario.” Treat inject information as credible unless the facilitator clarifies otherwise.
- Do not contact real vendors, customers, regulators, media, or external partners as part of the exercise.
- Do not make production changes, open real incident tickets, or send real customer communications based solely on this exercise.
- All scenario facts are fictional and for internal exercise use only.
- Participants should speak in terms of actions, owners, timing, dependencies, communications, and evidence to preserve.

Facilitator Ground Rules

- Keep the group focused on decisions rather than deep technical troubleshooting.
- Prompt for executive, operational, technical, customer, and regulatory perspectives at each stage.
- Record unclear accountabilities as findings rather than resolving them informally during the exercise.
- Escalate scenario pressure only if participants resolve an inject too quickly or avoid key decision points.

6. Facilitation Plan and Timeline

The scenario clock covers a single business day from initial detection through restoration. The facilitation clock assumes a 90-minute tabletop session.

Facilitation Time	Scenario Time	Activity	Facilitator Focus
00:00–00:10	N/A	Opening, objectives, roles, rules of engagement	Confirm participants understand decision-focused format.
00:10–00:25	09:00	Inject 1: Customer login failures rise sharply	Triage, severity, incident command, first communications.
00:25–00:45	10:30	Inject 2: Reassurance versus restoration decisions	Mitigation activation, failover, service prioritization, public messaging.
00:45–01:05	12:00	Inject 3: Stabilization with uncertain recovery timeline	Operating picture, recovery uncertainty, alternate channels, update cadence.
01:05–01:20	14:00	Inject 4: Service restoration and recovery	Stand-down criteria, regulatory assessment, evidence preservation, lessons learned.
01:20–01:30	N/A	Final debrief and immediate observations	Capture strengths, gaps, owners, and next actions.

Facilitation Rhythm

- **Inject delivery:** Read the inject aloud and allow participants one minute to absorb the information.
- **Clarifying questions:** Answer only with information in the inject or plausible facilitator clarifications; avoid resolving uncertainty too quickly.
- **Decision checkpoint:** Ask, “What decisions are required now, who owns them, and what is the next update time?”
- **Observation capture:** Scribe decisions, owners, timeframes, assumptions, risks, and unresolved dependencies.

7. Initial Situation Brief

The organization delivers consumer online and mobile banking through public-facing digital platforms supporting authentication, account access, and customer-initiated transactions. During a peak usage window, customers begin reporting widespread failures to access digital banking services. The bank’s public status page becomes intermittently unavailable, increasing confusion and customer frustration.

Early indicators suggest a high-volume denial-of-service event affecting public banking channels. The organization must quickly determine how to classify the incident, what technical and business functions to activate, which customer journeys to prioritize, whether to invoke contracted DDoS mitigation providers, and how much information to share with customers, employees, executives, regulators, and other stakeholders.

Opening Facilitator Prompt

- Assume this is happening today during a high-volume customer usage period.
- Use your current incident, crisis, communications, vendor, and regulatory processes.
- Do not assume root cause, attribution, or restoration timing unless stated in an inject.
- Focus on decisions, accountabilities, coordination, customer impact, and evidence preservation.

Known at Start of Exercise

Known	Unknown
• Customer access to online/mobile banking is degraded. • The status page is intermittently unavailable. • Customer complaints and contact center volume are increasing. • The incident affects public-facing digital channels.	• Exact cause and attack type. • Duration and restoration timeline. • Whether mitigation will fully restore service. • Whether there are separate issues with authentication, DNS, CDN/ WAF, or infrastructure capacity.

8. Phased Injects

Inject 1 – Customer Login Failures Rise Sharply

EXERCISE ELAPSED
00:10–00:25

SCENARIO TIME
09:00

STAGE
Initial detection

PRIMARY FOCUS
Triage and escalation

Inject

Customers report widespread failures to access online banking and mobile services. The bank's public status page becomes intermittently unavailable. Social media complaints increase rapidly and the contact center reports a significant spike in calls related to login timeouts, mobile app errors, and inability to view account balances.

What Participants Know

- Online banking and mobile banking are unavailable or degraded for many customers.
- The public status page is unstable, limiting the bank's ability to reassure customers.
- External visibility is increasing through social media and customer complaints.
- Root cause is not confirmed. DDoS is suspected but not yet validated.

Discussion Questions

- How is the incident triaged, classified, and escalated?
- Who owns the initial incident command function and who opens the coordination bridge?
- What telemetry confirms DDoS versus general service degradation, misconfiguration, or provider outage?
- Which customer journeys must be preserved first: login, balance viewing, transfers, password reset, card controls, or service-status communications?
- What immediate internal notifications are required, and who receives the first situation update?
- What customer-facing holding statement should be drafted before root cause is fully confirmed?

Decision Points

Decision	Expected Decision Owner	Information Needed
Declare major incident / cyber incident?	Incident commander or duty incident manager	Customer impact, monitoring alerts, service availability, business impact.
Activate crisis-management structure now or continue technical triage?	Crisis lead / executive sponsor	Severity, customer impact, media visibility, expected duration.
Publish initial customer message despite incomplete root cause?	Communications lead with legal/compliance review	Approved facts, service impact, next update time.

Expected Actions

- Open and classify a major incident with severity, impact statement, and known affected services.
- Stand up an incident coordination bridge and assign incident commander, scribe, technical leads, and business liaison.
- Notify executive, cyber, technology, customer support, communications, legal/compliance, and vendor-management stakeholders.
- Increase monitoring on public-facing services, authentication failures, CDN/WAF, DNS, ISP connectivity, and application health.
- Begin a decision/action log capturing time, owner, rationale, and unresolved assumptions.
- Prepare a concise customer holding statement and internal employee guidance.

Facilitator Notes

Encourage participants to distinguish between technical diagnosis and business-impact assessment. Test whether they identify customer trust, reputation, contact center surge, and regulatory visibility as early concerns, not just infrastructure issues.

Observation Criteria

- Was an incident commander identified?
- Were business impact and customer impact captured alongside technical symptoms?
- Was the status-page dependency recognized as a communications risk?
- Was a first update cadence established?

Inject 2 – Reassurance Versus Restoration Decisions

EXERCISE ELAPSED
00:25–00:45

SCENARIO TIME
10:30

STAGE
Active disruption

PRIMARY FOCUS
Mitigation and prioritization

Inject

Technical teams report that inbound traffic volumes against public banking channels are far above baseline and include patterns consistent with volumetric and application-layer denial-of-service activity. Leadership must decide how much information to release publicly, which services to prioritize, and whether to invoke external scrubbing, CDN/WAF, traffic-filtering, or ISP support. Mitigation options are available but may require controlled traffic rerouting and temporary degradation of nonessential functions.

What Participants Know

- The incident is affecting customer access at scale.
- Senior leaders must balance restoration, customer reassurance, reputational protection, and operational stability.
- External mitigation services can be engaged, but tradeoffs exist, including false positives, latency, blocked legitimate customers, and rollback complexity.
- Customer support channels are under strain and need approved guidance.

Discussion Questions

- When should external scrubbing, ISP filtering, CDN/WAF rule changes, or bot mitigation be activated?
- Which customer services should be preserved first, and which can be temporarily rate-limited, deferred, or disabled?
- Who approves failover decisions and customer-facing messaging?
- How should communications differ for customers, front-line support, executives, employees, and regulators?
- What guidance should branches, call centers, and digital support teams receive?
- How will misinformation, speculation, or fake support messages on social media be monitored and addressed?

Decision Points

Decision	Options to Discuss	Risks / Tradeoffs
Invoke external DDoS mitigation now or continue internal containment?	Immediate provider activation; staged provider engagement; internal controls only for another update cycle.	Activation delay may prolong outage; aggressive filtering may block legitimate customers.
Prioritize core account access only or preserve broader service set?	Read-only account access; login and balance view only; transfers and payments limited; full service attempted.	Too broad may reduce stability; too narrow may increase customer frustration and contact center load.

Publish detailed technical status or limited holding statement?	High-level customer impact update; technical description; no public update until confirmed.	Too little information fuels panic; too much detail may be inaccurate or operationally sensitive.
---	---	---

Expected Actions

- Engage contracted DDoS mitigation, ISP, CDN/WAF, or scrubbing capability according to authority and runbook.
- Define critical customer journeys and authorize temporary degradation of nonessential services if needed.
- Coordinate technical mitigation with change-control, rollback, and monitoring requirements.
- Issue approved customer, employee, and contact center communications with a specific next-update time.
- Establish social media monitoring and escalation for misinformation or impersonation.
- Document mitigation decisions, risks accepted, and expected service impacts.

Facilitator Notes

Push participants to articulate who owns the tradeoff between breadth of service and platform stability. Surface conflicts between communications transparency and technical uncertainty. Ask whether status communications are resilient if the primary status page is unavailable.

Observation Criteria

- Were provider engagement thresholds clear?
- Were service-priority decisions business-led and technically informed?
- Was customer support given actionable wording, not just “monitor the situation”?
- Were legal/compliance and communications involved early enough?

Inject 3 – Stabilization with Uncertain Recovery Timeline

EXERCISE ELAPSED

00:45–01:05

SCENARIO TIME

12:00

STAGE

Partial stabilization

PRIMARY FOCUS

Operating picture and uncertainty

Inject

Mitigation measures appear to reduce the worst of the disruption, but service performance remains inconsistent. Some customers can access online or mobile banking after retries; others still experience timeouts during login or transaction initiation. Customer complaints decline slightly, but transaction delays and authentication instability continue. Leadership does not yet have a reliable estimate for full restoration.

What Participants Know

- Some DDoS mitigation appears effective.
- Customer impact remains material, especially for login and account access.
- Full restoration timing is uncertain.
- Senior leadership is asking for a revised operating picture, customer impact assessment, and recovery timeline.

Discussion Questions

- What business services should now be prioritized for partial restoration?
- What criteria determine that customer impact is acceptable enough to move from crisis mode to controlled recovery?
- Are manual or alternate customer-service workarounds sufficient if disruption continues for the rest of the business day?
- What executive updates and communications cadence should be used while timing remains uncertain?
- What external stakeholders, if any, should be briefed at this stage?
- What data is needed to quantify customer impact and support regulatory assessment?

Decision Points

Decision	Expected Decision Owner	Discussion Focus
Maintain crisis posture or reduce to major incident management?	Crisis lead	Customer impact, stability trend, media visibility, residual risk.
Expand or narrow service availability?	Digital banking owner with technology lead	Performance stability, customer need, operational risk.
Set restoration estimate externally?	Communications lead with incident commander and legal/compliance	Confidence level, risk of overpromising, next update cadence.

Expected Actions

- Reassess incident severity, customer impact, and business-priority services.
- Publish updated internal and external status messaging with caveated facts and a next update time.
- Track business, reputational, customer-service, and technology impacts in a common operating picture.
- Validate resilience measures, alternate channels, contact center scripts, and branch guidance.
- Begin planning for structured recovery, evidence preservation, and post-incident review.
- Confirm whether regulatory notification thresholds must be assessed, even if formal notification is not yet required.

Facilitator Notes

This inject tests whether participants can manage uncertainty without losing discipline. Ask how they avoid overpromising on restoration timing and how they maintain executive confidence when technical telemetry is still evolving.

Observation Criteria

- Was a common operating picture created and kept current?
- Did communications reflect uncertainty without sounding evasive?
- Were workarounds realistic for a prolonged outage?
- Was regulatory assessment treated as a structured process, not an afterthought?

Inject 4 – Service Restoration and Recovery

EXERCISE ELAPSED
01:05–01:20

SCENARIO TIME
14:00

STAGE
Recovery and closure

PRIMARY FOCUS
Stand-down and lessons learned

Inject

Traffic conditions normalize and online/mobile banking services return to expected performance. The major disruption is considered contained. Leadership must now manage post-incident reporting, customer reassurance, review of service-prioritization decisions, vendor performance, and lessons learned. Teams must also consider the possibility of recurrence within the next several days.

What Participants Know

- Online and mobile banking access has returned to normal performance.
- The immediate disruption has been contained.
- Customer confidence and post-incident communications remain important.
- A structured post-incident review is required.

Discussion Questions

- What are the conditions for formally standing down the crisis-management structure?
- What customer follow-up communications are required, and through which channels?
- Were workarounds, service-prioritization decisions, and mitigation choices adequate?
- What regulatory, legal, internal, or board reporting should be initiated?
- What logs, telemetry, decisions, approvals, communications, and provider artifacts should be preserved?
- What changes are needed before a recurrence or longer-duration attack?

Decision Points

Decision	Expected Decision Owner	Evidence Needed
Declare service restored and close major incident?	Incident commander with crisis lead approval	Service health, monitoring stability, customer impact trend, provider confirmation.
Stand down crisis cell?	Crisis lead	Residual risk, communications completed, recovery owner assigned.
Initiate external or regulatory reporting?	Legal/compliance lead	Impact duration, customer impact, materiality assessment, jurisdictional obligations.
Retain heightened monitoring?	SOC and IT operations	Threat persistence, provider intelligence, recurrence risk.

Expected Actions

- Confirm service restoration using agreed metrics and monitoring windows.
- Communicate recovery status to customers, employees, executives, and support teams.
- Preserve logs, traffic telemetry, provider reports, incident timeline, decisions, approvals, and communications artifacts.
- Launch after-action review with assigned owners and due dates.
- Review DDoS provider performance, contractual response expectations, status-page resilience, and customer-channel capacity.
- Maintain heightened monitoring and define recurrence response triggers.

Facilitator Notes

Drive discussion toward measurable improvements, not narrative closure. Ask what would change if the attack lasted 24 hours, recurred the next morning, or coincided with a major payroll or payment deadline.

Observation Criteria

- Were restoration and stand-down criteria explicit?
- Were evidence and decision records preserved for review and reporting?
- Were customer confidence and recurrence risk addressed?
- Were improvement actions assigned to named owners?

9. Coordination Mechanisms and Communications

Recommended Operating Model

Forum	Purpose	Lead	Cadence During Active Disruption
Technical incident bridge	Diagnose service impact, coordinate DDoS mitigation, manage provider actions, validate service restoration.	Incident commander / IT operations lead	Continuous, with summarized updates every 15 minutes.
Crisis-management cell	Make business-impact, customer, executive, continuity, and reputational decisions.	Crisis lead	Every 30 minutes or at each decision gate.
Customer support coordination	Provide contact center, branch, digital support, and social media teams with approved guidance.	Customer support lead	At each communications update, then as needed.
Executive update channel	Provide concise status, impact, decisions needed, risks, and next update time.	Crisis lead or designated executive liaison	Every 30–60 minutes depending on impact.
Regulatory/legal assessment	Assess notification obligations, materiality, evidence requirements, and external statements.	Legal/compliance lead	At severity changes and before external reporting decisions.

Minimum Situation Report Elements

Situation Report Template
Time / prepared by:
Incident severity and current status:
Services affected:
Customer impact:
Technical assessment:
Actions completed:
Decisions needed:
Communications issued:
External / regulatory considerations:
Risks and assumptions:
Next update time:

Decision and Action Log Fields

Field	Example
Time	10:35 scenario time
Decision / action	Activate external DDoS scrubbing provider.
Owner	Network/DDoS mitigation lead.
Approver	Technology executive / incident commander according to policy.

Rationale	Traffic volumes exceed internal mitigation threshold; customer impact remains material.
Risk accepted	Potential latency and false positives for legitimate customers.
Follow-up	Validate service metrics and customer impact after traffic reroute.

Communication Templates

Initial Customer Holding Statement

"We are aware that some customers are having difficulty accessing online and mobile banking. Our teams are working to restore normal service as quickly as possible. Customer funds remain protected. We will provide the next update at [time] through our official channels."

Contact Center / Branch Guidance

"Acknowledge the customer impact, avoid speculating on cause, direct customers to official updates, capture urgent-service needs, and escalate cases involving time-sensitive payments or hardship through the defined support path."

Executive Update Format

"Current status; customer impact; affected services; technical hypothesis; actions underway; decisions required; communication posture; regulatory/legal assessment; next update time."

Recovery Communication

"Online and mobile banking services have returned to normal performance. We apologize for the disruption and will continue enhanced monitoring. Customers who experienced issues should retry access or contact support through official channels."

10. Business and Technical Impacts to Explore

Business Impacts

- Customer inability to access account information or initiate digital transactions.
- Increased contact center volume, longer wait times, and branch escalation pressure.
- Reputation damage and loss of customer confidence.
- Potential delays for time-sensitive transfers, payments, or customer requests.
- Executive, board, media, and regulatory visibility.
- Operational backlog after restoration.

Technical Impacts

- Degraded availability of internet-facing banking services.
- Authentication instability, login timeouts, elevated 5xx errors, or session failures.
- Status page disruption reducing transparency.
- Elevated load on edge infrastructure, CDN/WAF, DNS, authentication, and origin services.
- Risk of false positives or legitimate customer blocking during mitigation.
- Monitoring and observability challenges during high-volume attack traffic.

Service Prioritization Matrix

Priority	Service / Journey	Exercise Discussion
Tier 0	Customer safety and official communications	Public status updates, fraud warnings, contact center guidance, branch scripts, alternative notification channels.
Tier 1	Login, balance view, card controls, urgent account access	Maintain or restore first; consider read-only access if transactional services add instability.
Tier 2	Transfers, payments, bill pay, account servicing	Risk-based prioritization based on deadlines, customer hardship, and operational impact.
Tier 3	Profile changes, statement downloads, marketing content, nonessential digital features	Candidate for temporary degradation, rate limiting, or deferral to preserve stability.

Facilitator Deep-Dive Prompts

- What threshold distinguishes a service outage from a cyber crisis?
- Who can authorize DDoS provider activation after hours?
- What happens if the status page is on the same affected infrastructure path?
- How will the organization avoid accidentally blocking legitimate customers during filtering?
- Which customer segments require special handling, such as vulnerable customers or time-sensitive business customers?
- What evidence should be preserved even if this appears to be “only” an availability incident?

11. Debrief, Observation, and Improvement Planning

Hotwash Questions

- What worked well in the first 30 minutes?
- Where were roles, decision rights, escalation thresholds, or approval paths unclear?
- Did participants establish a common operating picture across technical and business teams?
- Were communications timely, accurate, and appropriately tailored to customers, employees, executives, and regulators?
- Were service-prioritization decisions risk-based and realistic?
- Were third-party dependencies and contractual response expectations understood?
- What would need to improve before running this exercise again?

Observer Worksheet

Capability Area	Confidence Rating 1–5	Evidence Observed	Improvement Action	Owner
Incident triage and severity classification				
Incident command and crisis activation				
DDoS mitigation provider engagement				
Service prioritization and continuity				
Customer and employee communications				
Legal/compliance/regulatory assessment				
Recovery and evidence preservation				

Likely Improvement Themes

- DDoS runbooks, provider contacts, escalation thresholds, and after-hours authority.
- Predefined customer journey tiers for digital banking continuity.
- Status page resilience and alternative official communication channels.
- Customer communication templates and approval flows.
- Contact center surge playbooks and branch escalation instructions.
- Common operating picture, situation report, and decision-log discipline.
- Provider performance metrics, contractual obligations, and post-incident reporting.

After-Action Report Outline

After-Action Report Outline

1. Executive summary
2. Exercise objectives and participants

3. Scenario timeline and decisions
4. Strengths observed
5. Gaps and root causes
6. Risk implications
7. Improvement plan with owners and due dates
8. Evidence and artifacts reviewed
9. Recommended retest or follow-up exercise

12. MITRE ATT&CK Mapping

This final section maps the tabletop scenario to the MITRE ATT&CK Enterprise framework. The exercise is intentionally availability-focused and does not assume broader intrusion lifecycle activity such as credential theft, persistence, lateral movement, malware deployment, or data exfiltration.

Tactic	Technique / Sub-Technique	How It Appears in the Scenario	Use in Exercise
Impact	T1498 – Network Denial of Service	High-volume traffic degrades or blocks access to public online and mobile banking resources.	Primary technique. Use to frame detection, mitigation, customer impact, and availability response.
Impact	T1498.001 – Direct Network Flood	Potentially applicable if telemetry shows direct volumetric traffic against exposed banking services.	Conditional sub-technique. Facilitator may introduce if participants ask about attack pattern details.
Impact	T1498.002 – Reflection Amplification	Potentially applicable if attack traffic is reflected or amplified through third-party infrastructure.	Conditional sub-technique. Useful for discussing ISP/scrubbing provider telemetry and filtering.
Impact	T1499 – Endpoint Denial of Service	Relevant only if specific application endpoints, authentication components, or access services are exhausted even when the network is not fully saturated.	Secondary / conditional technique. Do not treat as confirmed without supporting telemetry.
Impact	T1499.002 – Service Exhaustion Flood	Potentially applicable if requests overwhelm web, API, DNS, or authentication services supporting digital banking.	Conditional sub-technique for technical discussion of endpoint/service saturation.
Impact	T1499.003 – Application Exhaustion Flood	Potentially applicable if attacker traffic targets resource-intensive application functions such as login or transaction workflows.	Conditional sub-technique for application-layer DDoS discussion.

Defensive Implications for Participants

- Recognize availability-focused attacks as cyber incidents when customer impact, external visibility, and threat indicators are present.
- Define clear thresholds for activating DDoS mitigation providers and for escalating from incident management to crisis management.
- Preserve traffic telemetry, provider reports, WAF/CDN/DNS logs, service health metrics, incident decisions, and customer-impact data.
- Coordinate cyber response, digital operations, customer support, communications, legal/compliance, vendor management, and executive leadership through a documented operating model.
- Avoid unsupported expansion of the scenario into data theft, malware, or fraud unless new evidence is introduced.

Source Scenario Elements Interpreted

Scenario Element	Exercise Interpretation
Target organization	Banking organization in the financial-services sector.
Target infrastructure	Online banking, mobile banking, authentication, public status communications.
Attack pattern	Flood public digital banking channels to deny customer access.
Incident	DDoS against online and mobile banking during peak customer usage.
Courses of action	Invoke DDoS traffic scrubbing/failover; implement customer channel outage communications.
Exercise notes	Customer login failures rise sharply; leadership balances reassurance, restoration, and service prioritization.

MITRE Reference Notes

Technique names and IDs were checked against the public MITRE ATT&CK Enterprise knowledge base for T1498 Network Denial of Service, T1498.001 Direct Network Flood, T1498.002 Reflection Amplification, T1499 Endpoint Denial of Service, T1499.002 Service Exhaustion Flood, and T1499.003 Application Exhaustion Flood. URLs: <https://attack.mitre.org/techniques/T1498/> ; <https://attack.mitre.org/techniques/T1498/001/> ; <https://attack.mitre.org/techniques/T1498/002/> ; <https://attack.mitre.org/techniques/T1499/> ; <https://attack.mitre.org/techniques/T1499/002/> ; <https://attack.mitre.org/techniques/T1499/003/>

End of exercise document.